



Security Scan Report

Tools: CodeQL, Gitleaks · generated 2026-06-01 10:49 UTC



10 critical issue(s) need attention

Critical issues are likely exploitable. Fix these first.



Issues by category

Deserialization of untrusted data

CODEQL

CWE-502

Critical · 9.8

4 findings

[User-provided data](1) flows to unsafe deserializer.

Where: `VulnerableApi/Controllers/DeserializationController.cs:21`

`VulnerableApi/Controllers/DeserializationController.cs:30` + 2 more occurrence(s)

Uncontrolled command line

CODEQL

CWE-078

CWE-088

Critical · 9.8

4 findings

This command line depends on a [user-provided value](1).

Where: `VulnerableApi/Controllers/CommandInjectionController.cs:17`

`VulnerableApi/Controllers/CommandInjectionController.cs:33` + 2 more occurrence(s)

Untrusted XML is read insecurely

CODEQL

CWE-611

CWE-827

CWE-776

Critical · 9.1

2 findings

This insecure XML processing depends on a [user-provided value](1) (DTD processing enabled in settings, insecure resolver set in settings).

Where: `VulnerableApi/Controllers/XxeController.cs:21` + 1 more occurrence(s)

Uncontrolled data used in path expression

CODEQL

CWE-022

CWE-023

CWE-036

High · 7.5

8 findings

This path depends on a [user-provided value](1).

Where: `VulnerableApi/Controllers/PathTraversalController.cs:14`

`VulnerableApi/Controllers/PathTraversalController.cs:23`

VulnerableApi/Controllers/PathTraversalController.cs:32
VulnerableApi/Controllers/PathTraversalController.cs:33 + 4 more occurrence(s)

SQL query built from user-controlled sources

CODEQL

CWE-089

High · 8.8

6 findings

This query depends on [this ASP.NET Core MVC action method parameter](1).

Where: VulnerableApi/Controllers/SqlInjectionController.cs:26
VulnerableApi/Controllers/SqlInjectionController.cs:45
VulnerableApi/Controllers/SqlInjectionController.cs:60 + 3 more occurrence(s)

Encryption using ECB

CODEQL

CWE-327

High · 7.5

2 findings

The ECB (Electronic Code Book) encryption mode is vulnerable to replay attacks.

Where: VulnerableApi/Controllers/CryptoController.cs:52 + 1 more occurrence(s)

Log entries created from user input

CODEQL

CWE-117

Medium · 6.1

2 findings

This log entry depends on a [user-provided value](1).

Where: VulnerableApi/Controllers/XssController.cs:22 + 1 more occurrence(s)

URL redirection from remote source

CODEQL

CWE-601

Medium · 6.1

2 findings

Untrusted URL redirection due to [user-provided value](1).

Where: VulnerableApi/Controllers/SsrfController.cs:23 + 1 more occurrence(s)

Missing XML validation

CODEQL

CWE-112

Medium · 4.3

1 finding

This XML processing depends on a [user-provided value](1) without validation because the 'XmlReaderSettings' instance does not specify the 'ValidationType' as 'Schema'.

Where: VulnerableApi/Controllers/XxeController.cs:21

Call to 'System.IO.Path.Combine' may silently drop its earlier arguments

CODEQL

Low

2 findings

Call to 'System.IO.Path.Combine' may silently drop its earlier arguments.

Where: VulnerableApi/Controllers/PathTraversalController.cs:13
VulnerableApi/Controllers/PathTraversalController.cs:31

Generic catch clause

CODEQL

CWE-396

Low

1 finding

Generic catch clause.

Where: `VulnerableApi/Controllers/SqlInjectionController.cs:64`

34 total finding(s) across 11 categories.